

10-Point HIPAA Privacy & Security Self-Audit

Prepared by: Transworld Medical Management, LLC

Introduction

In the **"Assess. Fix. Govern."** model, the first step to clinical excellence is identifying hidden vulnerabilities. This self-audit is designed for Practice Administrators to conduct preliminary documentation and walkthrough check of their facility's HIPAA posture.

Phase 1: Administrative Governance

1. **Business Associate Agreements (BAAs):** [Yes / No]
 - Do you have a signed BAA for every vendor that creates, receives, maintains, or transmits Protected Health Information (PHI) on your behalf (e.g., IT, Billing, Answering Services)?
2. **Notice of Privacy Practices (NPP):** [Yes / No]
 - Is your NPP physically posted in a clear location in the waiting area, and is a copy available for download on your website?
3. **Security Risk Analysis (SRA):** [Yes / No]
 - Has your practice conducted or updated a formal Security Risk Analysis within the last 12 months? This is a mandatory requirement for MIPS and HIPAA compliance.

Phase 2: Technical Safeguards (The TWMM Technical Edge)

4. **Unique User Identifiers:** [Yes / No]
 - Does every staff member use a unique login for the EMR and workstations? Shared "Front Desk" or "Nurse" accounts are high-risk violations.
5. **Automatic Log-Off:** [Yes / No]
 - Are all workstations configured to automatically log off or lock after a period of inactivity (typically 3–5 minutes)?
6. **Data Encryption:** [Yes / No]
 - Is "At-Rest" encryption enabled on all portable devices (laptops, tablets) and is all outbound email containing PHI encrypted?

Phase 3: Physical & Operational Security

7. **Workstation Positioning:** [Yes / No]
 - Are computer monitors positioned so that they are not visible to patients or unauthorized visitors in hallways or the waiting area?
8. **Secure Disposal:** [Yes / No]
 - Are there dedicated, locked shred bins in all areas where paper PHI is handled, and is a Certificate of Destruction provided by your vendor monthly?
9. **Access Controls:** [Yes / No]
 - Are server closets, medical record rooms, and pharmaceutical storage areas kept locked when not in use, with restricted access for non-clinical staff?
10. **Right of Access Logs:** [Yes / No]
 - Do you maintain a log of patient record requests to ensure you meet the mandatory 30-day fulfillment window required by the Office of Civil Rights (OCR)?

Audit Summary & Next Steps

If you checked "No" to any of the items above, your practice is currently **at risk** for audit failure and potential fines.

Transworld Medical Management specializes in the **Remediation** of these specific gaps. We don't just find errors; we fix the workflows and implement **PowerBI Governance Dashboards** to ensure your compliance remains green year-round.

Ready to move from Assess to Fix? Contact us at admin@transworldmm.com or visit transworldmm.com to schedule your comprehensive Practice Health Assessment.